

CyberCase Intelligence Framework

เอกสารเจาะลึกสถาปัตยกรรมระบบ, โครงสร้างข้อมูล และ End-to-End Execution Flow

เวอร์ชัน 2.0 (Engineering Architecture)

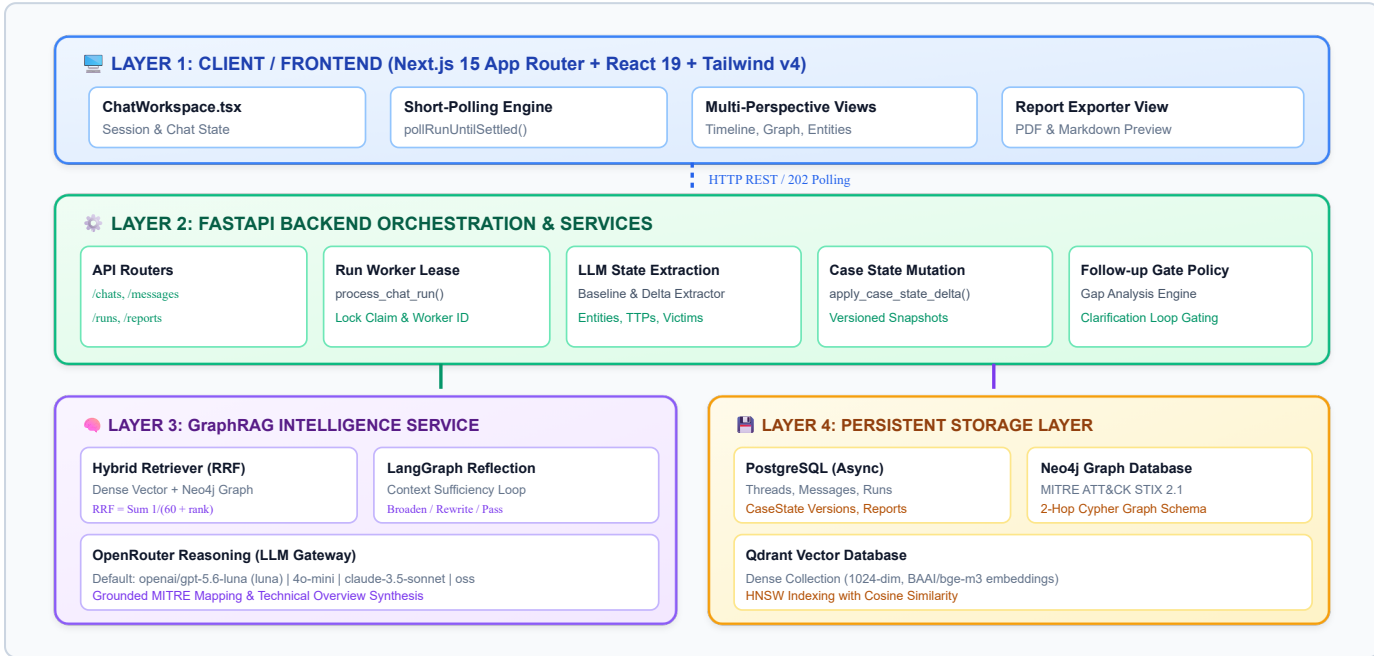
Framework: Agentic RAG for Incident Analysis

Frontend: Next.js 15 (App Router) + React 19

Backend: FastAPI + SQLAlchemy (Async)

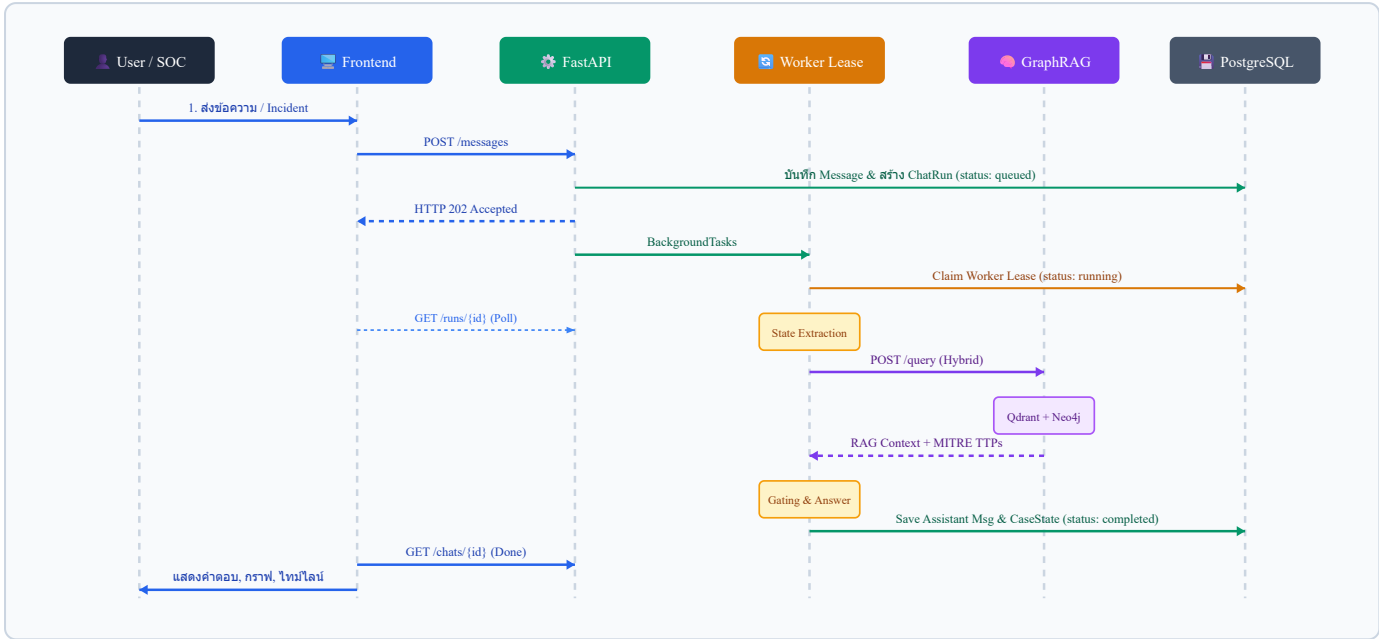
Graph & Vector: Neo4j + Qdrant (BGE-M3)

1. แผนผังสถาปัตยกรรมระบบรวม (High-Level System Architecture Diagram)



CyberCase Intelligence Framework

2. ขั้นตอนการทำงานแบบ End-to-End (Sequence Flow Diagram)



3. รายละเอียดขั้นตอนการประมวลผล 4 โหมดการทำงาน (Operational Modes)

Mode A: Initial Incident Ingestion (ข้อความแรก)

- รัน `run_baseline_extraction()` สกัด Entities (Threat Actor, Tools, Vulnerabilities, Victims) และ Relationships
- บันทึกเป็น Case State Version 1 พร้อมจัดโครงสร้าง Timeline Events
- นำ Case State มา Project เป็น Search Query ส่งไปที่ GraphRAG Service เพื่อดึง TTPs
- สังเคราะห์ Main Case Overview และส่งให้ Follow-up Gate ตรวจสอบหาช่องว่างข้อมูล

Mode B: Add Case Info (ข้อมูลส่วนเพิ่ม)

- รัน `run_case_state_delta_extraction()` เปรียบเทียบข้อมูลใหม่กับ Version ก่อนหน้า
- สกัดเฉพาะส่วนต่าง `CaseStateDelta` (New Entities, Updated Attributes, New Edges)
- รัน `apply_case_state_delta()` รวม Delta เข้ากับ State เดิม (Auto version bump)
- ปรับปรุง Query และดึง RAG Context เพื่ออัปเดตบริบทวิเคราะห์เคสฉบับสมบูรณ์

Mode C: Clarification Exchange (การตอบคำถามชี้แจง)

- เมื่อสถานะเป็น `awaiting_followup` ผู้ใช้พิมพ์ตอบคำถามของ Assistant
- ระบบนำคำถามที่ค้างอยู่ (Pending Question) + คำตอบของผู้ใช้มารวมเข้ากับ Case State เดิม
- นำ Clarification History ทั้งหมดส่งไป GraphRAG เพื่อวิเคราะห์ Threat Intelligence ใหม่
- หากข้อมูลครบถ้วน ปรับสถานะเป็น `answered`

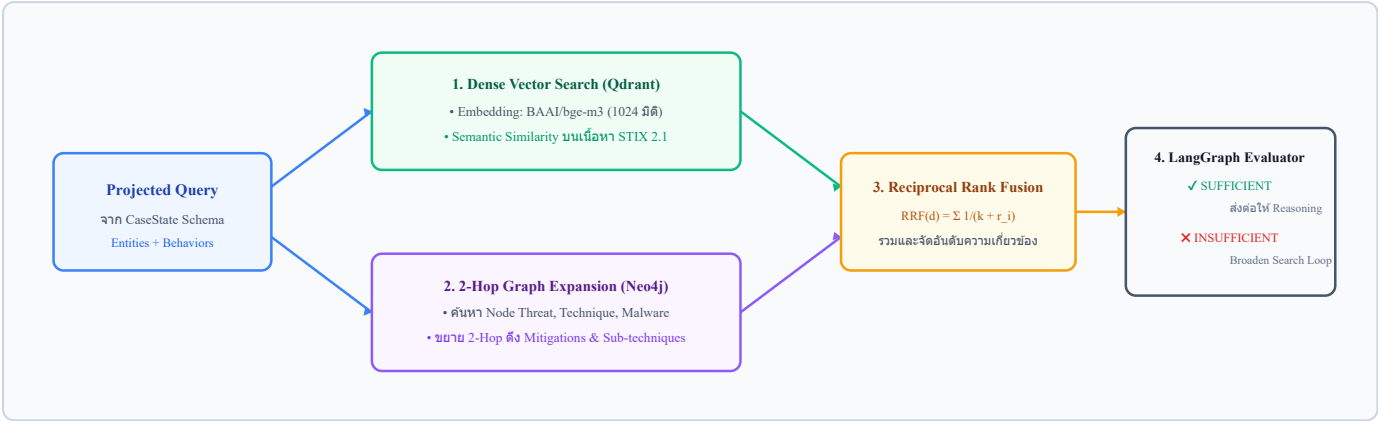
Mode D: Targeted Ask Q&A (การถามเจาะจง)

- ผู้ใช้ตั้งคำถามเฉพาะจุด (เช่น "มัลแวร์ตัวนี้มีวิธีแก้ไข Mitigation อย่างไร?")
- ระบบข้ามขั้นตอน State Mutation และใช้ Case State Snapshot + Latest Analysis Context ล่าสุด
- เรียก LLM ในโหมด `question_answer` ตอบคำถามอย่างรวดเร็วและตรงจุด
- บันทึกผลลัพธ์เป็นข้อความตอบกลับโดยไม่กระทบโครงสร้างหลักของคดี

CyberCase Intelligence Framework

3. เจาะลึกกลไก GraphRAG Hybrid Retrieval & LangGraph Evaluator

4. สถาปัตยกรรมการสืบค้นแบบไฮบริด (Dense Vector + Graph Expansion)



5. รายละเอียดส่วนประกอบหลักของ GraphRAG

โมดูล / ไฟล์	การทำงานและตรรกะเชิงลึก	พารามิเตอร์และการตั้งค่า
hybrid_retriever.py	ทำ Dense Vector Search ใน Qdrant และรัน Cypher Query บน Neo4j เพื่อขยาย Node ข้างเคียง (Depth=2) แล้วผสานคะแนนด้วย RRF	- Vector: BAAI/bge-m3 (1024-dim, Cosine) - RRF constant \$k=60\$ - Graph Depth: 2-Hop neighbors
agent_graph.py	LangGraph State Machine ควบคุมวงรอบการประเมิน Context Sufficiency หากข้อมูลไม่พอจะปรับ Query เพื่อค้นหาแบบกว้างขึ้น (Broaden)	- Loop Budget: สูงสุด 2-3 iterations - Fallback: Acknowledge limit เมื่อหมดโควตา
context_builder.py	จัดรูปแบบ Context ทางเทคนิคจาก STIX 2.1 (Technique ID, Tactic Name, Detection Description, Mitigation Advice) เพื่อป้อนให้ LLM	- Token budget optimization - Structured MITRE Markdown formatting
model_registry.py	จัดการเชื่อมต่อ OpenRouter API และแมป Model Alias ไปยัง Target Model ID	- luna → openai/gpt-5.6-luna (Default) 4o-mini, oss, sonnet, 4o

CyberCase Intelligence Framework

4. การจัดการ Case State, Gap Analysis & นโยบายขอข้อมูลชี้แจง (Clarification Gate)

6. โครงสร้างข้อมูลสืบทวน (Case State Schema)

หัวใจสำคัญของระบบคือการรักษา **Case State** ซึ่งเป็นโครงสร้างข้อมูลสถานะคดีที่มี Versioning อย่างชัดเจน จัดเก็บไว้ใน PostgreSQL และถูกอัปเดตในทุกๆ ข้อความ:

1. Entities (ตัวตนที่ตรวจพบ)

- threat_actor : ชื่อกลุ่มแฮกเกอร์, Aliases
- malware / tool : ชื่อไฟล์, โทรเจน, สคริปต์
- vulnerability : เลข CVE, ช่องโหว่ซอฟต์แวร์
- victim / target : องค์กร, IP, Hostname
- indicator : Hash, Domain, Port

2. Relationships (ความสัมพันธ์)

- Triplet Form: (Subject, Predicate, Object)
- ตัวอย่าง: "DEV-0586" — [targets] — "Ukraine Govt"
- Confidence Score: high, medium, low
- Status: reported, suspected, not_established

3. Timeline & Evidence

- timestamp / period : วันที่เวลาที่ตรวจพบ
- event_description : พฤติกรรมการโจมตี
- evidence_ids : ข้อความอ้างอิงต้นฉบับ
- mitre_technique_id : รหัส TTPs ที่แมปได้

7. ตรรกะการทำงานของ Follow-up Clarification Gating (`gate.py`)

เพื่อป้องกันไม่ให้ระบบถามคำถามซ้ำๆ ระบบใช้ **FollowUpPolicy** ควบคุมการตัดสินใจอย่างรัดกุม:

ลำดับการตัดสินใจของ Clarification Gate (Policy Decision Rules)

DETERMINISTIC GATING

ขั้นที่ 1: ตรวจสอบ Max Clarification Depth — จำกัดไม่ให้ถามเกินโควตาสูงสุดที่ตั้งไว้ (ปกติไม่เกิน 2-3 ครั้งต่อเคส) เพื่อไม่ให้กระทบ User Experience

ขั้นที่ 2: Gap Analysis Execution — วิเคราะห์ว่ามีข้อมูลวิกฤต (Critical Gaps) เช่น ไม่ทราบ Initial Access Vector, ไม่ทราบ Payload Hash, หรือไม่ทราบ OS เป้าหมายหรือไม่

ขั้นที่ 3: Policy Classification —

- PROCEED_WITH_ANSWER : หากข้อมูลเพียงพอต่อการจัดทำ TTPs เบื้องต้น ให้ส่งผลวิเคราะห์ทันที
- REQUEST_CLARIFICATION : หากขาดข้อมูลสำคัญที่จำเป็นต่อการยืนยันกลุ่มภัยคุกคาม ให้ตั้งสถานะ awaiting_followup และเลือก Gap ที่สำคัญที่สุด 1 คำถาม
- NO_ADDITIONAL_INFO_AVAILABLE : หากผู้ใช้เคยตอบแล้วว่าไม่มีข้อมูลเพิ่มเติม ระบบจะไม่ถามซ้ำในประเด็นเดิม

CyberCase Intelligence Framework

5. รายละเอียด API Endpoints, การจัดการข้อผิดพลาด และระบบสร้างรายงาน

8. สรุปรายการ REST API Endpoints (`/api/v1/chats`)

Method	Endpoint Path	HTTP Status	คำอธิบายและ Payload
POST	/api/v1/chats	201 Created	สร้าง Thread สนทนาใหม่สำหรับเคส {"title": "..."}
GET	/api/v1/chats	200 OK	ดึงรายการ Thread ทั้งหมดพร้อมสถานะล่าสุด
GET	/api/v1/chats/{thread_id}	200 OK	ดึงรายละเอียดเคส ประวัติแชต Messages, CaseState, Entities, Timeline
POST	/api/v1/chats/{id}/messages	202 Accepted	ส่งข้อความใหม่และเริ่ม Run เบื้องหลัง {"content": "...", "action": "add_case_info"}
GET	/api/v1/chats/{id}/runs/{run_id}	200 OK	Polling ตรวจสอบสถานะ Run (queued → running → completed / failed)
POST	/api/v1/chats/{id}/reports	201 Created	ส่งเคราะห์รายงานวิเคราะห์เคสอย่างเป็นทางการ (Structured Report JSON)
GET	/api/v1/chats/{id}/reports/{r_id}/pdf	200 OK	ดาวน์โหลดรายงานเคสเป็นไฟล์ PDF (Content-Type: application/pdf)

9. ระบบสร้างรายงานวิเคราะห์เคส (Structured Report Generation)

ระบบรายงานถูกออกแบบภายใต้มาตรฐาน **Grounded Cybersecurity Reporting** เพื่อให้มั่นใจว่าทุกข้อความในรายงานมีหลักฐานอ้างอิงชัดเจน:

โครงสร้างรายงาน (Structured Schema)

- Executive Summary:** สรุปภาพรวมและระดับความเสี่ยงของเหตุการณ์
- Threat Actor & Malware Profile:** ข้อมูลระบุตัวตนและเครื่องมือที่ใช้
- Attack Lifecycle & TTPs:** โทมไลน์ตามขั้นตอน Cyber Kill Chain / MITRE
- Recommended Mitigations:** มาตรการตอบสนองและป้องกันเร่งด่วน
- Limitations & Unverified Data:** ข้อจำกัดของข้อมูลที่ยังไม่ได้รับการยืนยัน

การเชื่อมโยงหลักฐาน (Claim Support Tagging)

ทุก Claim ในรายงานจะถูกระบุ Support Type:

- user_reported**: ข้อมูลที่ผู้ใช้แจ้งเข้ามาโดยตรง
- extraction_candidate**: ข้อมูลที่สกัดได้จากไฟล์ Log หรือ Narrative
- mitre_mapping_candidate**: เทคนิคที่แมปได้จากฐานข้อมูล Neo4j
- general_technical_knowledge**: ความรู้ทั่วไปด้านเทคนิคของ LLM